

RAPPORT GRC

Gouvernance · Risques · Conformité

Projet PixelStore — Infrastructure AWS sécurisée

Date : 13 June 2026

Auteurs : Matthieu Broquard · Dorian Poncelet · Jimmy Barbier

Formation : Jedha Bootcamp — Cybersécurité Fullstack

Classification : CONFIDENTIEL

Référentiels : ISO 27001:2022 · NIST CSF 2.0 · FAIR · RGPD

Analyse réalisée avec GRC Agent Hermes — scripts ISO 27001, NIST CSF 2.0, FAIR Monte Carlo

SOMMAIRE

1.	Présentation du projet PixelStore	3
2.	Méthodologie d'analyse	3
3.	Gap Analysis ISO 27001:2022 — résultats	4
4.	Scoring maturité NIST CSF 2.0 — résultats	6
5.	Quantification FAIR — exposition financière	7
6.	Plan de traitement des risques prioritaires	9
7.	Synthèse et recommandations	10

1. PRÉSENTATION DU PROJET PIXELSTORE

Contexte

PixelStore est une application e-commerce de vente de smartphones développée dans le cadre du cursus Jedha Bootcamp Cybersécurité Fullstack. Le projet couvre le développement applicatif (Flask 3.1, Python), le déploiement sur infrastructure AWS via Terraform IaC, et la sécurisation de l'ensemble de la chaîne.

Composant	Détail	Statut sécurité
Application	Flask 3.1 — 9 smartphones (799€–1 899€)	HTTP uniquement (pas de TLS)
Compute	EC2 Auto Scaling Group — t2.micro min1/max2	SSM Session Manager (sans clé SSH)
Load Balancer	Application Load Balancer — Multi-AZ eu-west-3	WAF attaché (OWASP + SQLi + RateLimit)
Base de données	RDS MySQL — Multi-AZ — db.t3.micro	Chiffré au repos — subnet privé
Stockage	S3 — assets statiques	Chiffré SSE-S3
Secrets	AWS Secrets Manager	Rotation configurable
Observabilité	CloudWatch (4 alarmes) + GuardDuty + CloudTrail	Actif — alertes CPU/erreurs
IaC	Terraform — 17 modules — 71 ressources	1 terraform apply (~15 min)
RPO / RTO	RPO 24h (snapshots RDS daily)	RTO 15 min (terraform apply)

Périmètre du présent rapport

L'analyse GRC porte sur l'intégralité du périmètre technique et organisationnel du projet : application Flask, infrastructure AWS, pratiques de développement et gestion de projet. Elle se base exclusivement sur les éléments observés — code source, configuration Terraform, rapport de pentest interne et documentation disponible.

2. MÉTHODOLOGIE D'ANALYSE

L'analyse a été conduite en trois phases indépendantes, correspondant à trois référentiels complémentaires. Chaque phase produit un résultat quantifié et des écarts actionnables.

Phase	Référentiel	Outil utilisé	Résultat produit
1 — Conformité	ISO 27001:2022	gap_analysis_iso27001.py	Score maturité CMMI par contrôle
2 — Maturité	NIST CSF 2.0	scoring_maturite_nist_csf.py	Score par fonction (0–4) + Tier
3 — Financier	FAIR Monte Carlo	calcul_fair.py	ALE annuel en euros (P50/P90/P95)

Échelles de mesure

Référentiel	Échelle	Seuil de conformité visé
ISO 27001:2022	CMMI 0 → 5 (0=inexistant, 5=optimisé)	Maturité ≥ 3 sur 90% des contrôles applicables
NIST CSF 2.0	Tier 1 → 4 (1=Partial, 4=Adaptive)	Tier 3 (Repeatable) — objectif organisations matures
FAIR	ALE en € — percentiles P50/P90/P95	P90 utilisé comme référence budget de défense

Sources d'information

- Code source Flask (app.py, models.py, routes.py)
- Infrastructure Terraform (17 modules — main.tf, variables.tf, outputs.tf par module)
- Rapport de pentest interne — 8 findings documentés (F1 à F8)
- Configuration AWS (WAF rules, Security Groups, NACLs, IAM policies, CloudWatch alarms)
- Documentation projet (README, notes d'architecture)

3. GAP ANALYSIS ISO 27001:2022

Résultats globaux

Indicateur	Valeur
Contrôles évalués	93 / 93 (couverture 100%)
Contrôles conformes (maturité ≥ 3)	26 / 93 — 28%
Score moyen de maturité	1,72 / 5
Verdict	Programme de mise en conformité 12–18 mois

Score par thème ISO 27001

Thème	Contrôles	Score moyen	Conformes ≥ 3 	Niveau
A.7 — Physiques	14	3,29 / 5	11 / 14 (79%)	Satisfaisant
A.8 — Technologiques	34	1,97 / 5	11 / 34 (32%)	Insuffisant
A.5 — Organisationnels	37	1,22 / 5	4 / 37 (11%)	Critique
A.6 — Personnels	8	0,25 / 5	0 / 8 (0%)	Critique

Note : Le score A.7 (Physiques) est élevé car AWS gère la sécurité physique des datacenters (datacenter locks, CCTV, accès biométrique) — ces contrôles sont délégués par contrat.

Écarts majeurs par thème

A.5 — Contrôles organisationnels (score 1,22/5)

Contrôle	Intitulé	Maturité	Observation
A.5.5	Contact avec les autorités	0	Aucun contact établi avec ANSSI / CNIL
A.5.19	Sécurité fournisseurs	0	AWS comme fournisseur — aucune clause sécurité formalisée
A.5.25	Évaluation incidents	0	Pas de procédure d'évaluation et décision sur incidents
A.5.26	Réponse aux incidents	0	Pas de procédure de réponse documentée
A.5.28	Collecte des preuves	0	Pas de procédure de préservation des preuves
A.5.36	Conformité avec politiques	0	Pas de processus de vérification de conformité aux politiques

A.6 — Contrôles personnels (score 0,25/5) — Thème le plus critique

Contrôle	Intitulé	Maturité	Observation
A.6.1	Vérification des antécédents	0	Absence totale — contexte académique sans processus RH
A.6.2	Conditions d'embauche sécurité	0	Pas de clauses sécurité dans les engagements
A.6.5	Responsabilités après emploi	0	Pas de procédure de départ sécurisé
A.6.6	Engagements de confidentialité	0	Aucun NDA / engagement signé
A.6.7	Politique travail à distance	0	Pas de politique formalisée
A.6.8	Signalement événements sécurité	0	Aucun canal de signalement défini

A.8 — Contrôles technologiques (score 1,97/5) — Écarts liés au pentest

Contrôle	Intitulé	Maturité	Lien pentest	Observation
A.8.24	Utilisation de la cryptographie	0	F1 — HTTPS absent	HTTP en clair — credentials exposés
A.8.11	Masquage de données	0	F5 — Énumération users	Pas de masquage champs sensibles

A.8.12	Prévention fuites (DLP)	0	—	Aucun outil DLP configuré
A.8.31	Séparation dev/test/prod	0	F8 — SECRET_KEY	Même clé utilisée en dev et prod
A.8.33	Données de test	0	—	Pas de politique données de test

4. SCORING MATURITÉ NIST CSF 2.0

Résultats globaux

Indicateur	Valeur
Sous-catégories évaluées	77 / 77
Score moyen global	0,69 / 4
Niveau global	Tier 1 — Partial (ad hoc, réactif)
Objectif cible	Tier 3 — Repeatable (formalisé, mesuré)

Score par fonction NIST CSF 2.0

Fonction	Description	Score	Tier	Priorité
PR — Protect	Contrôles de protection	1,18 / 4	Tier 1	Bonne base (IAM, chiffrement, réseau)
ID — Identify	Connaissance actifs et risques	0,83 / 4	Tier 1	Cartographie des flux manquante
DE — Detect	Détection événements et anomalies	0,73 / 4	Tier 1	Corrélation événements absente
GV — Govern	Stratégie de gestion du risque	0,62 / 4	Tier 1	Aucune politique formalisée
RC — Recover	Reprise après incident	0,25 / 4	—	CRITIQUE — aucun plan de reprise
RS — Respond	Réponse aux incidents	0,23 / 4	—	CRITIQUE — aucune procédure

Visualisation — Niveaux de maturité par fonction (sur 4)

Fonction	Niveau de maturité	Score
GV — Govern		0.62 / 4
ID — Identify		0.83 / 4
PR — Protect		1.18 / 4
DE — Detect		0.73 / 4
RS — Respond		0.23 / 4
RC — Recover		0.25 / 4

Écarts critiques — Fonctions RS et RC (61 écarts total)

Les fonctions RS (Respond) et RC (Recover) sont quasi inexistantes. Les 13 sous-catégories RS et 8 sous-catégories RC sont toutes à score 0.

Code	Sous-catégorie	Fonction	Score	Action requise
RS.MA-01	Plan de réponse exécuté	Respond	0	Créer un plan de réponse aux incidents
RS.MA-02	Incidents triés et validés	Respond	0	Définir critères de triage
RS.AN-07	Preuves préservées	Respond	0	Procédure forensique minimale
RS.AN-08	Cause racine déterminée	Respond	0	Post-mortem structuré
RS.CO-02	Parties prenantes notifiées	Respond	0	Plan de communication incident
RC.RP-01	Plan de reprise exécuté	Recover	0	Tester le terraform apply comme PRA
RC.RP-03	Intégrité sauvegardes vérifiée	Recover	0	Tester les snapshots RDS
RC.RP-04	Fonctions critiques restaurées	Recover	0	Documenter l'ordre de restauration

5. QUANTIFICATION FAIR — EXPOSITION FINANCIÈRE

Trois scénarios de risque ont été quantifiés via simulation Monte Carlo (10 000 itérations). Chaque scénario est modélisé selon le modèle FAIR : $ALE = LEF \times LM$, avec $LEF = TEF \times Vuln$ et $LM = PLM + SLM$. Les hypothèses sont issues du rapport de pentest et de l'analyse de l'infrastructure.

Synthèse des trois scénarios

Scénario	Source	ALE moyen /an	P90 /an	P95 /an
F1 — HTTP en clair (interception credentials)	Pentest F1 Absence HTTPS	144 800 €	275 000 €	331 600 €
F8 — SECRET_KEY faible (forge de session Flask)	Pentest F8 Clé triviale	30 200 €	57 200 €	70 700 €
RGPD — Fuite BDD RDS (notification CNIL 72h)	Analyse infra RDS exposable	17 000 €	33 700 €	43 200 €
TOTAL exposition annuelle		~192 000 €	~366 000 €	~446 000 €

Lecture : P90 = dans 90% des simulations, la perte annuelle sera inférieure à cette valeur. La valeur P90 est la référence recommandée pour dimensionner le budget de défense.

Scénario 1 — Interception de credentials (HTTP en clair — F1 pentest)

Facteur FAIR	Min	Mode (likely)	Max	Description
TEF (fréquence tentatives/an)	0,5	2,0	8,0	Attaque de type MITM sur réseau non sécurisé
Vuln (probabilité de succès)	0,60	0,80	0,95	Absence de TLS — interception triviale
PLM (perte directe /événement)	2 k€	15 k€	80 k€	Remédiation technique + notification clients
SLM (perte secondaire /évén.)	5 k€	25 k€	150 k€	Atteinte réputation + sanctions potentielles

Statistique	ALE	LEF (événements/an)	LM (perte/événement)
Moyenne (P50)	144 800 €	2,17	66 400 €
P75	192 600 €	—	—
P90 — référence	275 000 €	3,64	104 500 €
P95	331 600 €	—	—
P99	448 200 €	—	—

Un certificat TLS via AWS Certificate Manager (ACM) est gratuit. L'activation sur l'ALB représente moins de 2h de travail et élimine l'intégralité de ce scénario — soit ~145 k€/an d'exposition supprimée.

Scénario 2 — Forge de session via SECRET_KEY faible (F8 pentest)

Facteur FAIR	Min	Mode	Max	Description
TEF	0,1	0,5	2,0	Attaquant ciblé découvrant la clé par bruteforce ou exposition
Vuln	0,20	0,40	0,70	Clé triviale — forge de cookie de session réalisable
PLM	5 k€	30 k€	100 k€	Usurpation comptes + remédiation
SLM	10 k€	50 k€	200 k€	Atteinte réputation + notification RGPD possible

Statistique	ALE	P90	P95
Moyenne	30 200 €	57 200 €	70 700 €

Correction : générer une SECRET_KEY de 32 octets aléatoires via `secrets.token_hex(32)` et la stocker dans AWS Secrets Manager.
Durée : 30 minutes.

Scénario 3 — Violation de données personnelles clients (RGPD — notification CNIL)

Facteur de Mitigation	Min	Mode	Max	Description
TEF	0,05	0,20	1,00	Fuite BDD RDS via exploitation combinée des vulnérabilités
Vuln	0,10	0,25	0,50	Mitigé par subnet privé RDS et Security Groups
PLM	10 k€	50 k€	200 k€	Investigation + notification CNIL (72h) + clients
SLM	20 k€	80 k€	500 k€	Amende RGPD possible + perte de confiance
Statistique	ALE		P90	P95
Moyenne	17 000 €		33 700 €	43 200 €

Ce risque est partiellement mitigé par l'architecture (RDS en subnet privé, Security Groups restrictifs). L'ajout de TLS (scénario 1) réduit également ce scénario en limitant l'exposition des credentials qui pourraient servir de vecteur d'entrée.

6. PLAN DE TRAITEMENT DES RISQUES PRIORITAIRES

Les actions sont classées par priorité selon deux critères : impact sur l'exposition financière FAIR et facilité de mise en œuvre. Les actions de niveau P1 peuvent être réalisées en moins d'une semaine.

P1 — Actions immédiates (< 1 semaine) — Coût estimé : < 4h de travail

Action	Lien	Impact ALE réduit	Effort	Méthode
Activer TLS/HTTPS sur l'ALB ISO A.8.24	NIST PR.DS-02 FAIR F1	-144 800 €/an	2h	AWS ACM : générer certificat gratuit → attacher à l'ALB listener 443 →
Régénérer SECRET_KEY Flask ISO A.8.31	NIST PR.DS-01 FAIR F8	-30 200 €/an	30 min	secrets.token_hex(32) → stocker dans AWS Secrets Manager → référer
Ajouter headers sécurité HTTP ISO A.8.26	NIST PR.PS-06 Pentest F3	Réduction F3	1h	Flask: Strict-Transport-Security, X-Frame-Options, X-Content-Type-Opti
Sécuriser les cookies session ISO A.8.26	Pentest F4/F6	Réduction F4/F6	30 min	SESSION_COOKIE_SECURE=True, SESSION_COOKIE_HTTPONLY=

P2 — Actions court terme (< 1 mois) — Gouvernance minimale

Action	Référentiel	Livrable	Effort estimé
Politique de réponse aux incidents	ISO A.5.26 NIST RS.*	Document 2 pages : détection → triage → escalade → post-mortem	4h
Registre des traitements RGPD Art.30	RGPD A.30 ISO A.5.14	Tableau : traitement / base légale / durée / destinataire	2h
Engagements de confidentialité	ISO A.6.6	NDA ou charte signée par chaque membre de l'équipe	1h
Canal de signalement sécurité	ISO A.6.8 NIST RS.CO-02	Adresse email dédiée ou ticket Jira — procédure écrite	1h
Test de restauration RDS snapshot	NIST RC.RP-03	PV de test : snapshot → restore → vérification intégrité	2h

P3 — Actions moyen terme (1–6 mois) — Maturité ISO 27001

Action	Référentiel	Objectif	Effort
Politique d'utilisation acceptable des actifs	ISO A.5.10	Couvrir les données clients et l'infra AWS	4h
Séparation environnements dev/test/prod	ISO A.8.31	Comptes AWS distincts ou VPC isolés	8h
Politique de gestion des mots de passe	ISO A.8.5 F7	Longueur mini 12 car. + complexité + no reuse	2h
Inventaire et classification des actifs	ISO A.5.9/A.5.12 NIST ID.AM	Cartographie : app + BDD + S3 + EC2 + IAM	1h
Clause sécurité fournisseur AWS	ISO A.5.19/A.5.20	Formaliser les responsabilités partagées AWS	2h
Plan de continuité documenté (PCA/PRI)	NIST RC.RP-01	Documenter : terraform apply comme PRA → RTO/RPO formels	4h

7. SYNTHÈSE ET RECOMMANDATIONS

Tableau de bord GRC

Référentiel	Score actuel	Cible	Gap	Verdict
ISO 27001:2022	1,72 / 5 (28% conformes)	4,0 / 5 (90% conformes)	-2,28	Programme 12–18 mois
NIST CSF 2.0	Tier 1 — 0,69 / 4	Tier 3 — 3,0 / 4	-2,31	Actions immédiates RS/RC
FAIR — ALE total	~192 000 € / an	< 30 000 € / an	-162 k€/an	2 actions = -175 k€/an
RGPD	Non conforme Art.30	Registre + DPO désigné	—	Registre à créer

Points forts identifiés

- ✓ Architecture réseau — VPC Multi-AZ, subnets publics/privés, Security Groups en cascade, NACLs : conforme Defense in Depth.
- ✓ IAM et accès SSH — SSM Session Manager sans clé SSH, IAM roles avec moindre privilège : conforme A.8.2, A.8.18.
- ✓ Secrets management — AWS Secrets Manager pour les credentials BDD : conforme A.8.24 (partiellement).
- ✓ Chiffrement au repos — RDS chiffré, S3 SSE-S3, EBS chiffré : conforme A.8.24.
- ✓ Observabilité — CloudWatch (4 alarmes), GuardDuty, CloudTrail activés : bonne base de détection.
- ✓ WAF — Règles OWASP Core Rule Set, protection SQLi et rate limiting : conforme A.8.23.
- ✓ IaC Terraform — Infrastructure reproductible en 15 min : base du PRA (RTO 15 min).

Points de risque persistants

- ✗ HTTPS absent — l'unique vulnérabilité à impact financier le plus élevé (144 800 €/an). Correction : < 2h.
- ✗ SECRET_KEY Flask non sécurisée — forge de session possible. Correction : 30 minutes.
- ✗ Absence totale de gouvernance personnelle (A.6) — aucun engagement de confidentialité, aucune procédure RH.
- ✗ Absence de plan de réponse aux incidents — NIST RS score 0,23 — aucune procédure documentée.
- ✗ Absence de plan de reprise formalisé — NIST RC score 0,25 — terraform apply comme PRA non documenté.
- ✗ Registre RGPD Article 30 inexistant — obligation légale non remplie.
- ✗ Séparation dev/test/prod inexistante — même SECRET_KEY, même configuration.

Priorisation ROI sécurité

Action	Coût estimé	ALE réduit /an	ROI annuel	Délai
TLS/HTTPS (ACM + ALB)	0 € (ACM gratuit) + 2h	-144 800 €	Immédiat	< 1 jour
SECRET_KEY → Secrets Manager	0 € + 30 min	- 30 200 €	Immédiat	< 1 jour
Headers HTTP + cookies sécurisés	0 € + 1,5h	-Réduction F3/F4	Immédiat	< 1 jour
Plan de réponse aux incidents (doc)	4h rédaction	Couverture RS	Court terme	< 2 sem.
Registre RGPD Art.30	2h rédaction	Conformité légale	Légal	< 1 mois

Conclusion — L'infrastructure AWS de PixelStore présente une base technique solide : Defense in Depth, IAM moindre privilège, chiffrement au repos, WAF configuré. Les lacunes critiques sont concentrées sur trois axes : l'absence de TLS (risque financier dominant), l'absence totale de gouvernance organisationnelle et humaine (A.6), et l'absence de procédures de réponse et reprise après incident (RS/RC). Les deux premières actions correctives (TLS + SECRET_KEY) représentent moins de 3 heures de travail pour une réduction d'exposition de 175 000 €/an.

Rapport généré le 13 juin 2026 — GRC Agent Hermes (ISO 27001 gap analysis, NIST CSF 2.0 scoring, FAIR Monte Carlo 10 000 itérations) — Jedha Bootcamp Cybersécurité Fullstack